



Protect • Comply • Thrive

Overview

The need

Our client, a US local authority, wanted to compare its information security practices with the security controls set out in Annex A of the information security management standard ISO/IEC 27001:2013.

The solution

IT Governance's ISO 27001 Gap Analysis consultancy service.

The benefit

Understanding the extent to which our client was following information security best practice, with the aim of improving its data processing activities.

ISO 27001 Gap Analysis

Case study

Background

Our client, a large US city council, provides residents with a full range of local government services, including social care, children's services, housing, libraries, and environmental services.

In the course of its daily activities, the council processes a vast amount of data relating to local residents, businesses, and other parties. Much of this data is very sensitive, so its protection is paramount, especially in light of the

increasing regulatory burden being placed on local authorities and the penalties that can be imposed for failing to protect residents' personally identifiable information (PII).

The council therefore commissioned IT Governance to carry out a gap analysis against ISO/IEC 27001:2013 (ISO 27001, the Standard), the international standard for information security management.

Requirements

Our client wanted to determine the extent to which it was following information security best practice with regard to the data it processes, as a breach could have serious consequences both for it and for the public.

It therefore decided to commission an assessment of its current security practices, using the best-practice controls in ISO 27001 as a benchmark.

ISO 27001 sets out the requirements for an information security management system (ISMS), a holistic approach to information security that comprises policies, procedures, guidelines, and associated resources and activities that, collectively managed by an organization, protect its information assets.

Annex A of the Standard contains a comprehensive list of 114 security controls and control objectives, which are typically selected and implemented as part of the organization's risk management process.

Implementing an ISMS enables an organization to secure its information in all forms, increase its resilience to cyber attacks, and, because it is based on a formally defined risk management process, adapt to evolving security threats and reduce the costs associated with information security.

It also helps an organization demonstrate that it has implemented appropriate technical and organizational measures to protect sensitive information, including personally identifiable information (PII).

(For organizations that want to go further, ISO 27001's privacy extension, ISO/IEC 27701:2019, was created with the aim of protecting PII and demonstrating compliance with data protection laws. Its requirements can be incorporated into any ISMS.)

Independently audited certification to the Standard is recognized around the world as an indication that an organization has implemented and maintains information security best practice.

The first step of any ISO 27001 implementation project is to conduct a gap analysis to determine how far short of the Standard's requirements your organization's existing information security practices fall.

Our client therefore commissioned a gap analysis to identify any security gaps or improvements that could be made to enhance its long-term information security management processes.

The authority's intention was to use this information to make specific changes to its information security program to bring it into line with international best practice in order to better protect the information it processes and reduce the risk of financial and reputational damage caused by breaches.

The process

A discovery phase, comprising interviews with key stakeholders covering the relevant control areas, was conducted on-site over several days.

As well as these interviews, we reviewed the council's relevant documents and records, where possible, to determine the extent of their conformity to each control in Annex A.

This analysis included an assessment of:

- Whether each of the 114 Annex A controls was likely to be required by the council and, if they were, whether they were currently in place
- The extent to which and/or how consistently the selected controls were implemented, operated, monitored, and evaluated

Our consultant then produced a compliance status report detailing the findings for each Annex A control, complete with recommendations for improvement.

Comparing the council's existing security practices against international best practice provided a clear understanding of where improvements can be made, organized according to importance.

The outcome

The findings of our gap analysis report were color-coded to help our client prioritize its approach to improving its information security practices: Red to indicate nonconformity with the relevant control requirements, yellow to indicate partial conformity and areas where improvement could be made, and green to indicate conformity.

Implementing an ISMS is a significant undertaking that requires focused investment of time and resource across the entire organization. Gaining the necessary high-level support for such a project therefore takes time, and not every organization has the capacity to achieve full compliance with ISO 27001 immediately.

Although our client is not yet in a position to implement all the elements of an ISO 27001-compliant ISMS or pursue certification to the Standard, we recommended that the council adopt an overarching information security policy. We therefore supplied a sample policy as part of our report.

The solution

The council was found to conform to 52% of the Annex A controls. Where it was not in conformance, we provided guidance on the improvements it needed to make.

In most cases, the necessary process improvements involved revising and improving documentation.

IT Governance's ISO 27001:2013 Gap Analysis service provides a specialist, in-person review of your information security posture against the requirements of ISO 27001.

This gives you a true picture of your ISO 27001 compliance gaps, as well as expert advice on how to scope your project and establish your project resource requirements.

One advantage over standalone questionnaire-based gap analyses is the level of expert analysis and insights you get from a specialist. With an in-person gap analysis, you will have a clear idea of the proposed scope of the ISMS, be able to set realistic project expectations, and obtain customized and detailed information necessary to develop a strong business case for implementing an ISO 27001-compliant ISMS.

Key features

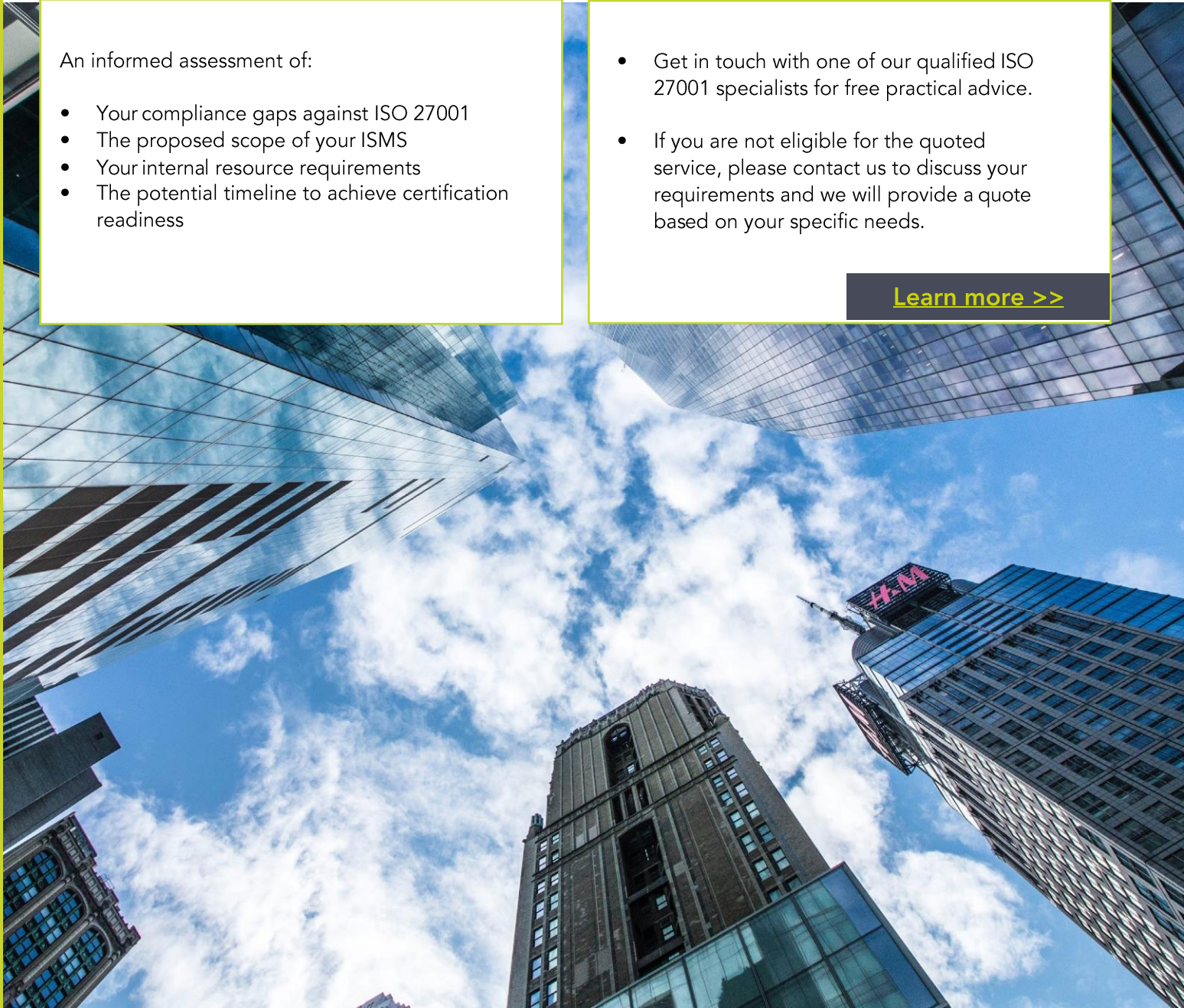
An informed assessment of:

- Your compliance gaps against ISO 27001
- The proposed scope of your ISMS
- Your internal resource requirements
- The potential timeline to achieve certification readiness

Need an ISO 27001 Gap Analysis?

- Get in touch with one of our qualified ISO 27001 specialists for free practical advice.
- If you are not eligible for the quoted service, please contact us to discuss your requirements and we will provide a quote based on your specific needs.

[Learn more >>](#)



Why choose IT Governance?



- Our ISO 27001 implementation methodology has been honed over 15 years.
- We are known as the global authority on ISO 27001 – our management team led the world's first ISO 27001 certification project (formerly known as BS 7799).
- We offer everything you need to implement an ISO 27001-compliant ISMS – you don't need to go anywhere else.
- We guarantee certification (provided you follow our advice!).
- You benefit from real-world practitioner expertise, not just academic knowledge.
- We have trained more than 7,000 professionals on ISO 27001 implementations and audits worldwide.
- We've helped more than 600 consultancy clients achieve certification to and compliance with ISO 27001.
- We have a proven and pragmatic approach to assessing compliance with international standards, no matter the size or nature of your organization.
- Our pricing and proposals are completely transparent, so you won't get any surprises.
- We can help small organizations prepare for ISO 27001 certification in three months.

USA

420 Lexington Avenue, Suite 300
New York, NY 10170

t: +1 877 317 3454
e: servicecenter@itgovernanceusa.com
w: www.itgovernanceusa.com



Europe

IT Governance Europe Ltd, Third Floor
The Boyne Tower, Bull Ring, Lagvooren,
Drogheda, Co. Louth, A92 F682, Ireland

t: +353 (0) 1 695 0411
e: servicecentre@itgovernance.eu
w: www.itgovernance.eu



UK

Unit 3, Clive Court, Bartholomew's
Walk, Cambridgeshire Business Park,
Ely, Cambs., CB7 4EA, United
Kingdom

t: +44 (0)333 800 7000
e: servicecentre@itgovernance.co.uk
w: <https://www.itgovernance.co.uk/>

